

Security+ 2.5 · Segmentation & Access Control

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.5 — Segmentation & Access Control (6:06) · [vídeo original](#) · [YouTube](#)

Isolamento network: VLAN / sub-rede / DMZ (screened subnet) — se um setor compromete, não contamina o resto. ACL (Access Control List) = o QUE pode entrar no recurso. Allowlist (default DENY — só o conhecido passa) > denylist (default ALLOW — bloqueio o conhecido). Microsegmentação = isolamento FINE-grained (o padrão de zero trust).

💡 Highlights que a prova cobra

- DMZ: zona entre internet e rede interna — o público mora lá
- Allowlist (deny-by-default) é MAIS SEGURA que denylist
- Microsegmentação: cada carga isolada — Zero Trust aplicado

🎯 Dicas de prova

- 'default deny, permit only known' = allowlist
- 'zone between internet and internal network' = DMZ/screened subnet

Cenário clássico: Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas o interno não alcança' = DMZ/screened subnet.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:
 - A) VLAN de voz
 - B) DMZ (screened subnet)
 - C) VPN
 - D) Intranet

2. Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:

- A)** Zero Trust
- B)** Defesa em profundidade
- C)** Fail-open
- D)** Segurança por obscuridade

3. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A)** Escassez
- B)** Autoridade + urgência
- C)** Prova social
- D)** Reciprocidade

4. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'DMZ: zona entre internet e rede interna — o público mora lá'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DMZ: zona entre internet e rede interna — o público mora lá...

5. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Allowlist (deny-by-default) é MAIS SEGURA que denylist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Allowlist (deny-by-default) é MAIS SEGURA que denylist...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Microsegmentação: cada carga isolada — Zero Trust aplicado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Microsegmentação: cada carga isolada — Zero Trust aplicado...

7. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'default deny, permit only known' = allowlist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'default deny, permit only known' = allowlist...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'zone between internet and internal network' = DMZ/screened subnet'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'zone between internet and internal network' = DMZ/screened subnet...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas o interno não alcança' = DMZ/screened subnet.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'DMZ: zona entre internet e rede interna — o público mora lá'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: DMZ: zona entre internet e rede interna — o público mora lá...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

1) B — DMZ (screened subnet). DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno.

2) B — Defesa em profundidade. Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger).

3) B — Autoridade + urgência. Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro.

4) D — Implementar a solução correspondente: DMZ: zona entre internet e rede interna — . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): DMZ: zona entre internet e rede interna — o público mora lá. As demais alternativas configuram violação

5) C — Implementar a solução correspondente: Allowlist (deny-by-default) é MAIS SEGURA . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): Allowlist (deny-by-default) é MAIS SEGURA que denylist. As demais alternativas configuram violações gra

6) D — Implementar a solução correspondente: Microsegmentação: cada carga isolada — Zer. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): Microsegmentação: cada carga isolada — Zero Trust aplicado. As demais alternativas configuram violações

7) C — Implementar a solução correspondente: 'default deny, permit only known' = allowl. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): 'default deny, permit only known' = allowlist. As demais alternativas configuram violações graves de co

8) C — Implementar a solução correspondente: 'zone between internet and internal network. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): 'zone between internet and internal network' = DMZ/screened subnet. As demais alternativas configuram v

9) B — Implementar a solução correspondente: Cenário: 'web server público mora numa sub. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas o interno não alcança' = DM

10) C — Implementar a solução correspondente: DMZ: zona entre internet e rede interna — . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): DMZ: zona entre internet e rede interna — o público mora lá. As demais alternativas configuram violação

